1 Muss ich wissen

Zero-Day, N-Day, Exploit, Payload

F8–9,18; Fragen F64–65

- Eine **Zero-Day Vulnerability** ist laut Kurs eine Schwachstelle, die den Entwicklern oder den für ihre Behebung zuständigen Personen unbekannt ist.
- Eine **N-Day Vulnerability** ist bekannt und öffentlich offengelegt, aber auf dem betroffenen System noch nicht gepatcht.
- Ein **Exploit** nutzt eine Schwachstelle aus, um ein Zielsystem zu kompromittieren, etwa für Malware-Installation oder Datendiebstahl.
- Ein **Payload** ist die gewünschte Aktion nach dem Eindringen, während der Exploit den Weg hinein bereitstellt.
- **Patching Grace Period** bezeichnet die zugestandene Zeit zur Bereitstellung eines Fixes, bevor ein System als non-compliant oder besonders gefährdet gilt.

Vulnerability Lifecycle: Ablauf und Angriffszeitpunkte

F9,23,26; Frage F64

- Der dargestellte **Disclosure-Pfad** lautet Vulnerability → Meldung → Patch → Public Disclosure → mögliche Post-Patch Exploitation.
- Ein **Zero-Day Exploit** kann vor der Behebung eingesetzt werden, während **Post-Patch Exploitation** weiterhin ungepatchte Systeme trifft.
- Die Entscheidung **Disclose oder Exploit** ist im Diagramm eine Verzweigung und kein zwangsläufiger linearer Ablauf.

White, Gray und Black Market

F24–25; Frage F64

- Im **White Market** werden Schwachstellen an Hersteller gemeldet, etwa gegen eine **Bug Bounty**, also eine Prämie für einen Schwachstellenbericht.
- Im **Gray Market** kaufen vor allem staatliche Stellen Zero-Days zur Nutzung, Bevorratung oder Weitergabe an Hersteller.
- Im **Black Market** kaufen kriminelle Gruppen bevorzugt einsatzfähige Exploit-Software und nutzen auch Schwachstellen mit bereits verfügbarem Patch.
- Die Folien kontrastieren **Good Geeks** mit Responsible Disclosure und Anerkennung als Anreiz mit **Bad Geeks**, die für Geld an Staaten oder Kriminelle verkaufen.

Responsible, Full und Coordinated Disclosure

F26–27,32; Fragen F66

- **Responsible Disclosure** bedeutet entdecken, vertraulich melden, Patch entwickeln lassen und anschließend veröffentlichen, gegebenenfalls nach einer vereinbarten Frist auch ohne fertigen Patch.
- **Full Disclosure** überspringt im Folienmodell die vertrauliche Meldung und die vorgelagerte Patch-Entwicklung und veröffentlicht die Schwachstelle direkt.
- **Coordinated Disclosure** stimmt mehrere betroffene Parteien ab, damit die frühe Veröffentlichung eines einzelnen Patches nicht die übrigen Systeme verrät.
- Ein **CERT** unterstützt die vertrauliche Meldung und Koordination, wobei die Folien beispielhaft Disclosure-Fenster von 45 oder 90 Tagen nennen.

1 Muss ich wissen – Tools und Fallstudien

ASLR und DEP: unterschiedliche Schutzideen

F14–17; Frage F65

- **Address-Space Layout Randomisation (ASLR)** verändert die Position wichtiger Speicherbereiche zufällig und erschwert das Vorhersagen von Adressen.
- **Data Execution Prevention (DEP)** verhindert die Ausführung von Code aus als nicht ausführbar markierten Datenbereichen wie Stack oder Heap.
- **Merke**: ASLR erschwert das Finden der Zieladresse, DEP erschwert das Ausführen eingeschleusten Codes im Datenspeicher.

Classic vs. Agentic Security Tools: drei Dimensionen

F20–22; Frage F66

- **Action Space**: Klassische Tools haben üblicherweise aufzählbare Aktionen, während LLM-Agenten unbestimmte Entscheidungen und Aktionsfolgen erzeugen.
- **Impact**: Klassische Tools wirken überwiegend deterministisch und im konfigurierten Zielbereich, während die Auswirkungen agentischer Tools unbestimmter sind.
- **Operator Population**: Klassische Tools verlangen Bedien- und Interpretationskompetenz, während Agenten offensive Fähigkeiten einer breiteren Nutzergruppe zugänglich machen.
- **AI-Herausforderung**: Schnellere Exploit-Entwicklung und mehr Schwachstellen verkürzen die praktische Patching Grace Period.
- **Bug-Bounty-Herausforderung**: Report Flooding und AI Slop erhöhen den Prüfaufwand und können Meldesysteme überlasten.

Stuxnet: kombinierter Angriff statt einzelner Wunderwaffe

F11,37; Frage F65

- Die **Stuxnet-Fallstudie** beschreibt einen gegen das iranische Nuklearprogramm gerichteten Angriff über eine mit USB beginnende Infektionskette.
- Die **Angriffskette** kombinierte Social Engineering, Zero-Days und alte ungepatchte Software einschließlich industrieller Steuerungstechnik.

Heartbleed: lesen über die Puffergrenze

F28–29; Frage F65

- **Heartbleed** betraf OpenSSL und entstand, weil die behauptete Länge eines Heartbeat-Payloads nicht mit der tatsächlichen Länge abgeglichen wurde.
- Der **Buffer Over-read** konnte fremden Speicherinhalt einschließlich privater Schlüssel offenlegen.
- Die **Reaktion** umfasste Patch und Key Rotation, während vorzeitiges Patchen die Schwachstelle anderen Angreifern verraten konnte.

Spectre und Meltdown: Side Channels und Tarnung

F30–32; Frage F65

- **Spectre** nutzt beobachtbare Cache-Effekte spekulativer Ausführung nach einer Branch Misprediction, um private Daten über Timing zu erschließen.
- **Meltdown** kann unberechtigt gelesene Daten aus den Cache-Effekten vorübergehender Out-of-order Execution rekonstruieren.
- **Kernel Page-Table Isolation / KAISER** wurde zunächst als Schutz gegen ein begrenztes Adressleck dargestellt, um die größere Schwachstelle während der Koordination nicht vorzeitig offenzulegen.

PHP2Shell: Aussage der Vorlesungsfallstudie

F33; Frage F65

- Laut **Folie** führten Leaks und vorzeitig veröffentlichte Patches dazu, dass Angreifer die Änderungen analysieren und noch vor dem geplanten Release angreifen konnten.
- Das **Lehrbeispiel** betont Angriffe unmittelbar nach Patch-Veröffentlichung und damit ein stark schrumpfendes Reaktionsfenster.

1 Muss ich wissen – Security Policy und MLS

Threat Model, Policy, Model

F4,40,42; Fragen F67

- Das **Threat Model** fragt, wer warum und wie angreifen könnte, bevor Policy, Implementation und Assurance festgelegt werden.
- Eine **Security Policy** formuliert Schutzziele kurz in normaler Sprache, typischerweise auf weniger als einer Seite.
- Ein **Security Model** beschreibt eine Security Policy formal, etwa im Bell-LaPadula-Modell.
- Die **Insider Threat** der Fallstudien ist ein illoyaler Mitarbeiter oder Malware auf dessen Gerät.

Multilevel Security (MLS): vertikale Informationsflüsse

F43–47; Fragen F67

- **MLS** ordnet Objects einer Classification $L(O)$ und Principals einer Clearance $L(S)$ zu, um **Confidentiality** zu schützen.
- Die gezeigte **Hierarchie** lautet Top Secret > Secret > Confidential > Official.
- Informationsflüsse sollen **nach oben statt nach unten** verlaufen, damit hoch eingestufte Inhalte nicht in niedriger eingestufte Bereiche gelangen.

Bell-LaPadula (BLP): die Regeln sicher unterscheiden

F47–48; Fragen F67

- **Simple Security Property – No Read Up**: Die Level-Bedingung für Lesen ist $L(O) \leq L(S)$.
- ***-Property – No Write Down**: Die Level-Bedingung für Schreiben ist $L(S) \leq L(O)$.
- **Discretionary Security Property**: Zusätzlich müssen Zugriffsrechte in einer Access Matrix den Zugriff erlauben.
- **Tranquillity Principle**: Die Einstufung eines Subject oder Object ändert sich nicht, während darauf Bezug genommen wird.
- Ein **sicherer Zustand** erlaubt nur Zugriffstupel (S, O, A), die Simple Security, *-Property und Discretionary Security erfüllen.

Basic Security Theorem: was wirklich bewiesen wird

F48; Fragen F67

- **Basic Security Theorem**: Sind der Anfangszustand und alle Zustandsübergänge sicher, bleibt das System immer in sicheren Zuständen.
- Die Folien definieren einen **sicheren Übergang** als Übergang von einem sicheren Zustand in einen anderen sicheren Zustand.

Trusted Computing Base und praktische BLP-Grenzen

F49–50; Fragen F67

- Die **Trusted Computing Base (TCB)** umfasst Hardware, Software und Verfahren, deren Versagen die Security Policy brechen könnte.
- **Memory Management**, Backup, Recovery und Kommunikation brauchen teilweise Zugriffe über mehrere Levels und vergrößern dadurch die TCB.
- Eine **große TCB** wie im Multics-Beispiel ist schwer mathematisch zu verifizieren.
- Der **License-Server-Fall** zeigt, dass eine Höherstufung für ein Kriegsschiffprojekt Nutzer eines niedrig eingestuften Handelsschiffprojekts aussperren kann.

1 Muss ich wissen – Covert und Lateral Flows

Covert Channels: am vorgesehenen Kanal vorbei

F51–52; Frage F67

- Ein **Covert Channel** überträgt Informationen über Ressourcen, die nicht als Kommunikationskanal vorgesehen sind.
- Ein **Timing Channel** kann durch veränderte CPU-Last signalisieren, ein **Storage Channel** durch Belegen von Plattenplatz.
- Damit kann **High nach Low** Informationen signalisieren, obwohl der offizielle BLP-Zugriff diesen Fluss verbietet.
- **Gegenmaßnahmen** sind geringere Kanalbandbreite oder mehr Rauschen, während eine Data Diode Datenfluss hardwareseitig auf eine Richtung beschränkt.

Multilateral Security und Lattice Model

F55–56; Fragen F68

- **Vertical Control** trennt höhere von niedrigeren Security Levels, **Lateral Control** trennt Bereiche auch bei gleicher Clearance.
- **Multilateral Security** verhindert unerwünschte horizontale Informationsflüsse zwischen Abteilungen, konkurrierenden Mandanten oder medizinischen Zuständigkeitsbereichen.
- Ein **Lattice Model** ergänzt Compartments beziehungsweise Labels und benötigt nur eine partielle Ordnung statt einer einzigen linearen Hierarchie.

UK/Scotland Medical Records: warum die Kontrolle scheiterte

F57–59; Frage F68

- Die **Fallstudie** beschreibt den Übergang von dezentralen Papierakten zu breit vernetzten Patientendaten mit rollen- und beziehungsbasiertem Zugriff.
- **Receptionists** erhielten zur Identitätsprüfung zu weitreichende Rechte und konnten dadurch auch vertrauliche psychiatrische Informationen lesen.
- Die **Lehre** ist granularer, sorgfältig entworfener Zugriff statt pauschaler Rechte nach Rolle.
- **Anonymization** ist schwierig, weil öffentliche und private Informationen in medizinischen Daten miteinander verknüpft sind.
- **OpenSAFELY** wird als positives Forschungsbeispiel genannt, bei dem Forschende keine Patientendaten herunterladen und Analysen in der Cloud erfolgen.

Chinese Wall, Delegation, Honeypots

F60–62; Fragen F68

- Das **Chinese Wall Model** verhindert Informationsflüsse zwischen konkurrierenden Parteien und damit Interessenkonflikte bei wechselnden Kundenbeziehungen.
- Das **Beispiel** ist eine Beratungs-, Bank- oder Anwaltsbeziehung, bei der die Arbeit für eine Firma zeitweise die Arbeit für deren Wettbewerber ausschließt.
- **Delegation** überträgt Befugnisse, Verantwortung oder Entscheidungen mit festgelegten Grenzen und Accountability.
- Das **Delegation-Beispiel** ist ein zeitlich begrenzter Zugriff auf Patientendaten nach Freigabe über die e-card.
- Ein **Honeypot** ist ein überwachtes Ködersystem, etwa eine falsche Prominentenakte, das unerlaubte Zugriffe von Insidern sichtbar machen soll.

2 Hinweise der Lehrperson

Quellenlücke: ausschließlich Hinweise aus Folien F63,69

- Für **Lecture 2 am 23.10.2026** liegt kein passendes Transkript vor, deshalb sind mündliche Schwerpunkte, Ausschlüsse und Terminänderungen nicht überprüfbar.
- **F63** nennt den zweiten Minitest am **30.10.2026** mit dem Zusatz „no class“ und alternativ **3.11.2026 (tba)** oder „after next class“, also noch keine eindeutig bestätigte Ersatzzeit.
- **F69** nennt fünf Minuten zu Vorlesungsbeginn und ein Moodle Quiz mit zwei bis drei Fragen, vor allem Definitionen sowie True/False, Multiple Choice, Lückentext oder mathematische Rechnungen.
- **Lernfokus laut F69** sind die Questions-Folien F64–68, aber das ganze Skript soll gelernt werden, sodass andere Inhalte nicht ausdrücklich ausgeschlossen sind.
- **Wertung laut F69**: zwölf Minitests zu je fünf Punkten, von denen die neun besten mit maximal 45 Punkten zählen.

3 Gut zu wissen

Patching, Incentives und Systemkontext F34–38

- **Bekannte Lücken** bleiben wichtig, weil nicht eingespielte Patches auch ohne neue Zero-Days ausnutzbare Systeme zurücklassen.
- **Operational Technology** lässt sich wegen Ausfallzeiten, Inkompatibilitäten oder notwendiger Rezertifizierung nicht immer sofort patchen.
- **Usability und Incentives** beeinflussen Updates und Nutzerverhalten, weshalb Systeme auch mit menschlichen Fehlhandlungen funktionieren müssen.

Composability und begrenzte Sicht F53–54

- **Composability**: Sichere Einzelkomponenten ergeben nicht automatisch ein sicheres Gesamtsystem.
- **Consistency**: Die Folien stellen Cover Stories für niedrige Einstufungen dem Zurückhalten höher eingestufter Informationen gegenüber.

Practical Part at Home: ergänzender Anhang, nicht ROP F71–83

- **Stack** enthält typischerweise lokale Variablen und Aufrufinformationen, während **Heap**-Speicher dynamisch reserviert und explizit freigegeben wird.
- **malloc** reserviert Speicher, ein Pointer speichert dessen Adresse, `*p` greift auf den Inhalt zu und **free** beendet die Lebensdauer der Reservierung.
- **Buffer Overflow** überschreitet eine Puffergrenze und kann benachbarte sicherheitsrelevante Daten beschädigen, ohne dass ein bestimmtes Ergebnis garantiert ist.
- **Use-after-free** greift über einen Dangling Pointer auf Speicher mit beendeter Lebensdauer zu und kann Daten offenlegen oder verändern.
- **Data Corruption** verändert Daten, während **Control-flow Hijacking** den Ausführungspfad verändert, etwa über einen manipulierten Function Pointer.

4 Selbsttest – 10 kurze Fragen mit Antworten

1. Was unterscheidet eine Zero-Day von einer N-Day Vulnerability?
Antwort: Zero-Day ist den für die Behebung Zuständigen unbekannt; N-Day ist öffentlich bekannt, auf dem betroffenen System aber ungepatcht. F8–9,64

2. Was unterscheidet Exploit und Payload?
Antwort: Der Exploit nutzt die Schwachstelle zum Eindringen; der Payload führt die beabsichtigte Aktion aus. F18,65

3. Wie unterscheiden sich White, Gray und Black Market?
Antwort: White bedeutet Meldung an Hersteller beziehungsweise Bug Bounty, Gray Verkauf vor allem an staatliche Stellen, Black krimineller Handel mit einsatzfähigen Angriffswerkzeugen. F24–25,64

4. Was unterscheidet Responsible von Full Disclosure?
Antwort: Responsible sieht vertrauliche Meldung und Zeit zur Behebung vor; Full veröffentlicht ohne diese vorgeschalteten Schritte. F26,66

5. Welche drei Dimensionen ändern sich bei Agentic Tools?
Antwort: Action Space, Impact und Operator Population werden unbestimmter beziehungsweise offensive Fähigkeiten breiter zugänglich. F20–22,66

6. Welche unterschiedlichen Hürden setzen ASLR und DEP?
Antwort: ASLR erschwert Adressvorhersagen; DEP verhindert die Codeausführung aus nicht ausführbaren Datenbereichen. F16–17,65

7. Wie heißen die zwei BLP-Level-Regeln samt Formeln?
Antwort: No Read Up verlangt $L(O) \leq L(S)$; No Write Down verlangt $L(S) \leq L(O)$, zusätzlich zur Access Matrix. F47,67

8. Was ist ein Covert Channel in MLS?
Antwort: Ein nicht vorgesehener Kommunikationsweg über gemeinsam genutzte Ressourcen, etwa CPU-Timing oder Plattenbelegung, der Informationen von High nach Low signalisieren kann. F51,67

9. Warum scheiterte der Zugriffsschutz im Medical-Records-Fall?
Antwort: Receptionists bekamen zur Identitätsprüfung zu breite Leserechte einschließlich vertraulicher psychiatrischer Daten. F58–59,68

10. Wie unterscheiden sich Chinese Wall, Delegation und Honeypot?
Antwort: Chinese Wall trennt konkurrierende Interessen, Delegation überträgt begrenzte Befugnisse und ein Honeypot macht unerlaubte Zugriffe auf einen Köder sichtbar. F60–62,68